GOBERNANZA DE INTELIGENCIA ARTIFICIAL CON ENFOQUE OCDE

Trabajo final · Informe

APM con IA agéntica: descubrimiento continuo y gobierno del portafolio

Arquitectura, conciliación con el catálogo y control humano en una plataforma de gestión del portafolio de aplicaciones

---

Autor	Davis Leonardo Cartagena Valera Brush
Docente	Jorge Pantoja
Caso	Portafolio de aplicaciones con IA agéntica
Fecha	Noviembre de 2026

Índice

Resumen ejecutivo....3
1. Introducción y contexto del caso....3
1.1 Planteamiento del problema....3
1.2 Descripción del caso y alcance....4
1.3 Procesos involucrados....5
1.4 Estado actual y primera calibración....5
2. Inventario y alineamiento con principios OCDE....6
3. Evaluación de riesgos y criterios de aceptabilidad....8
3.1 Criterios de aceptabilidad diferenciados....9
4. Gobernanza de proyectos y gestión de proveedores....10
4.1 Checklist de evaluación del proveedor y de la solución IA....10
4.2 Gobernanza de agentes IA....11
4.3 Clasificación de datos por sensibilidad....12
4.4 Indicadores (KPI) y primera medición....13
4.5 Mecanismo de detención y contingencia....13
5. Lineamientos operativos para uso responsable de IA....14
5.1 Clasificación de usos de IA agéntica....14
5.2 Lineamientos para IA generativa....14
6. Modelo institucional de gobernanza de IA....15
6.1 Estructura de roles y responsabilidades....15
6.2 Integración normativa....16
6.3 Hoja de ruta adaptable....16
7. Conclusiones y próximos pasos....17
Glosario....19
Bibliografía....20

Resumen ejecutivo

Este informe propone la gobernanza de la IA agéntica de una plataforma APM (Application Portfolio Management) para el equipo de Arquitectura TI de una organización con un parque de aplicaciones heterogéneo. La tesis es que la IA debe aplicarse donde está el cuello de botella —descubrir y mantener al día el inventario— y no solo en la conversación sobre un catálogo que se supone completo. Un pipeline de cuatro agentes (Code-to-Catalog, Dark Data Miner, Reconciliador Semántico y Micro-Nudge) extrae evidencia de repositorios, CI/CD, contratos y TDR (Términos de Referencia), la concilia con el catálogo existente y pregunta a los responsables solo lo que no puede resolver con reglas.

El análisis aplica los principios de la OCDE con 10 dimensiones éticas y 5 dimensiones de impacto. Los riesgos principales son la vinculación errónea de entidades, los datos personales presentes en commits y contratos, la fatiga por micro-nudges y el sesgo de automatización de los aprobadores. Los controles centrales constan en el diseño: cada valor cita su evidencia primaria; un score heurístico de 0 a 1 con un umbral único deja los casos dudosos en «Requiere Verificación»; los candidatos huérfanos (posible Shadow IT) pasan a revisión humana; y solo los atributos técnicos extraídos de forma determinista se publican automáticamente, con procedencia y de forma reversible. Todo lo demás requiere aprobación de Gobierno de Arquitectura.

La primera corrida del piloto de calibración, sobre 36 casos de prueba, produjo una señal metodológica pero no concluyente: la combinación que mejor rinde en calibración (0,60 / 0,01) no generaliza en el conjunto de evaluación y ningún umbral de revisión alcanza error cero. Por eso los umbrales siguen siendo propuestas y el piloto debe repetirse sobre un conjunto verificado más amplio antes de F3. Arquitectura TI es la dueña del producto, de los agentes y de sus reglas. La iniciativa está en la fase F0 (Cimientos): existen el portal de documentación, el modelo ArchiMate versionado como código y el prototipo del pipeline; nada está en producción.

1. Introducción y contexto del caso

1.1 Planteamiento del problema

Problema. El equipo de Arquitectura TI no logra mantener un inventario de aplicaciones que refleje la realidad. Cuando una aplicación cambia de dueño, de versión o de proveedor, la ficha sigue mostrando el estado anterior, y el catálogo deja de ser una fuente de decisión para convertirse en un trámite. El problema no es la falta de un repositorio —hay varios— sino que el costo de mantenerlo actualizado supera el valor que produce.

Causas. La captura es manual y burocrática —cuestionarios largos, planillas paralelas y una CMDB incompleta— y compite con el trabajo operativo: los **incentivos están mal alineados**. Hay una **dispersión sin árbitro**: repositorios y despliegues, contratos y TDR en PDF, conocimiento que solo existe en las personas; cada fuente habla un idioma distinto y nadie define qué fuente manda para cada atributo. Hay también una **identidad sin dueño**: la misma aplicación aparece con nombres, códigos y alcances diferentes, y nadie responde por el identificador que diría si dos registros son la misma cosa. A eso se suma que las herramientas de APM priorizan el análisis sobre la captura —suponen un dato limpio que no existe— y que las licencias comerciales quedan fuera del presupuesto. Detrás de estas causas hay un patrón

común: el costo de mantener el dato lo paga quien lo reporta, el beneficio lo recibe otra área y no existe un estándar compartido. El presupuesto es la cuarta restricción, y por eso el diseño se apoya en fuentes abiertas.

Consecuencias. Sin un inventario confiable aparece Shadow IT: aplicaciones y contratos que operan fuera de la visibilidad de TI, con vulnerabilidades y fin de vida (EOL) que nadie correlaciona. Las decisiones de inversión, racionalización (TIME) y retiro se toman sobre datos incompletos. Cada auditoría exige un barrido manual de emergencia que vuelve a degradarse, y el equipo pierde confianza en el catálogo y deja de usarlo, lo que acelera su deterioro. Ese círculo justifica un APM entendido como sistema que baja el costo de captura y preserva la identidad de los activos, con la IA puesta en el descubrimiento y la reconciliación.

Respuesta de diseño. Cada causa tiene su contraparte: la dispersión se atiende con autoridad única por atributo y procedencia; la identidad, con un identificador estable y reconciliación anclada en el catálogo; el costo de captura, con extracción automática y micro-nudges. Al incentivo responden la consulta abierta a todo TI, las notificaciones por evento a dueños y responsables —una CVE nueva, un fin de vida, un contrato por vencer, una evidencia que contradice un dato validado o un atributo obligatorio faltante— y una política de la Dirección de TI que hace del mantenimiento de la ficha parte del proceso operativo. El sistema devuelve al equipo lo que sabe de sus aplicaciones y la organización respalda la obligación; el riesgo residual —consultar sin reportar— se controla con esa política, la completitud visible y la medición de la brecha entre uso y registro.

1.2 Descripción del caso y alcance

El caso es una organización con un portafolio de aplicaciones complejo: muchas aplicaciones desarrolladas o mantenidas por proveedores externos, con información repartida entre repositorios de código, contratos, una CMDB (base de datos de gestión de configuración) y hojas de cálculo, y un catálogo que se mantiene a mano. El equipo de Arquitectura TI diseña una plataforma APM con tres objetivos: (i) descentralizar el registro, de modo que los equipos de aplicación mantengan sus propias fichas (Fact Sheets); (ii) relacionar los activos mediante vínculos explícitos definidos en un metamodelo, como aplicación–capacidad o componente tecnológico–aplicación; y (iii) mantener el inventario al día con IA agéntica.

El análisis se sitúa en una organización peruana de tamaño medio, con un parque de aplicaciones amplio y equipos distribuidos. Los ejemplos y las pruebas del prototipo se apoyan en un conjunto de prueba propio. La normativa peruana se aplica como marco de referencia y su alcance concreto lo confirman Cumplimiento y Legal; no se afirma una exigencia legal específica. La arquitectura se modela en ArchiMate 3.2 (The Open Group, 2022) como código versionado y se publica en un portal de documentación. El APM se plantea como registro maestro de los datos de arquitectura y estrategia (criticidad, ciclo de vida, capacidades, decisiones) e ingiere el resto desde fuentes autoritativas: la CMDB, los catálogos públicos de vulnerabilidades y fin de vida y, mediante agentes, los repositorios de código y los contratos.

La IA agéntica se aplica en dos capas. La primera (upstream) es un pipeline de descubrimiento continuo con cuatro agentes que construye y actualiza los Fact Sheets a partir de la realidad técnica y contractual. La segunda (downstream) usa el catálogo ya conciliado para gestionar vulnerabilidades y obsolescencia, racionalizar el portafolio (TIME: tolerar, invertir, migrar, eliminar), simular escenarios (what-if) y consultar el catálogo, primero mediante un servidor MCP (Model Context Protocol) y, de forma opcional y posterior, mediante un chat. La pregunta

que guía el informe es cómo gobernar esa IA para que mantenga el inventario con mínima intervención humana sin perder el control humano ni la trazabilidad (OCDE, 2024, 2025). Los términos técnicos se explican en el Glosario.

El modelo se plantea para una organización genérica para que las decisiones de diseño no dependan de una institución concreta. La elección es deliberada: la contratación, la aprobación y las reglas de publicación cambian entre organizaciones, mientras que el descubrimiento, la identidad, la procedencia y el control humano se mantienen. La adaptación a cada contexto se resuelve con las condiciones de aplicabilidad y los perfiles de entrada de la sección 6.3.

1.3 Procesos involucrados

Los procesos se describen a nivel funcional, tal como aparecen en la documentación del diseño. Los cinco primeros forman el pipeline de descubrimiento; el último agrupa las capacidades downstream, que dependen de un catálogo ya poblado.

Tabla 1.1 — Procesos involucrados y rol de la IA

Proceso	Qué haría la IA en el proceso	Partes interesadas	Fuente en el diseño
Descubrimiento técnico (repositorios y CI/CD)	El Agente 1 lee manifiestos, dependencias y despliegues con parsers deterministas, sin LLM; genera evidencia con hash de commit y ruta de archivo y sugiere un responsable técnico que siempre se confirma por micro-nudge.	Equipos de desarrollo, Arquitectura TI	IA agéntica (Agente 1); Gobierno y procedencia de datos
Extracción de contratos y TDR (dark data)	El Agente 2 aplica OCR y extracción guiada por esquema con LLM para obtener proveedor, vigencia, SLA y licencias; cada valor cita documento, página y cláusula.	Área de contrataciones, Arquitectura TI	IA agéntica (Agente 2)
Reconciliación con el catálogo	El Agente 3 ancla la evidencia en el catálogo existente, propone vínculos N:M con un score de 0 a 1 y envía huérfanos y conflictos a revisión humana.	Arquitectura TI, Gobierno de Arquitectura	IA agéntica (Agente 3); Gobierno de datos
Notificaciones y micro-nudges	Ante una CVE nueva, un fin de vida, un contrato por vencer, una discrepancia o un atributo faltante, el sistema avisa al momento al dueño y al responsable. El Agente 4 pregunta en un clic solo lo que las reglas no resolvieron, con límite de frecuencia y escalamiento al arquitecto.	Dueños técnicos y desarrolladores, arquitecto	IA agéntica (Agente 4); notificaciones
Aprobación de arquitectura	No decide: presenta el Fact Sheet con citas y diferencias en una bandeja de aprobación; los atributos críticos solo se publican con aprobación humana.	Gobierno de Arquitectura, arquitecto responsable	Gobierno y procedencia de datos
Capacidades downstream	Sobre el catálogo conciliado: prioriza vulnerabilidades (CVE, CVSS, EPSS), vigila fin de vida (EOL), apoya TIME y what-if y responde consultas por servidor MCP.	Seguridad de la Información, Arquitectura TI, Dirección	IA agéntica; Roadmap (F2, F4, F5)

1.4 Estado actual y primera calibración

La hoja de ruta del producto define seis fases: F0 cimientos, F1 catálogo núcleo, F2 tecnologías y seguridad, F3 ingesta continua, F4 IA agéntica y F5 analítica avanzada. La iniciativa está en F0, en curso: el portal se publica automáticamente, el modelo ArchiMate está versionado como código y existe un prototipo (MVP) del pipeline con los cuatro agentes. El prototipo se ejecuta sobre un conjunto de prueba de 21 repositorios, 15 contratos y 36 casos etiquetados, e incluye un evaluador con métricas por clase, matriz de confusión y comparación de parámetros. Nada está

en producción y las fases F1 a F5 están planificadas, por lo que hay margen para resolver la gobernanza antes de activar agentes sobre datos reales.

El prototipo se ejecutó sobre ese conjunto y se hizo una primera calibración del score. El resultado no fue concluyente: la combinación que mejor rinde en calibración no generaliza en el conjunto de evaluación y ningún umbral de revisión alcanza error cero. Por eso los valores 0,60 / 0,01 y el umbral 0,85 se mantienen como propuestas, no como parámetros validados. El detalle metodológico —splits, métricas, intervalos y protocolo de etiquetado— se documenta con el prototipo (ver documentación del MVP). Siguen pendientes la selección del proveedor de LLM y la verificación de sus términos, el análisis contra ISO/IEC 42001 y la política interna de IA.

La propuesta recomienda construir con fuentes abiertas: no se adquieren licencias nuevas y se usan fuentes y formatos abiertos (endoflife.date, NVD, OSV, SBOM (lista de componentes de software) y metadatos al estilo Backstage). La recomendación responde al presupuesto y a la portabilidad; una organización que ya tenga un proveedor de APM/EA puede reutilizarlo si garantiza la propiedad de sus datos, la exportación en formatos abiertos y una ruta de salida. Azure es la arquitectura objetivo, pero el diseño es portable a la capa gratuita de Azure o de GCP, y el LLM se consume detrás de una capa de proveedor intercambiable. El LLM interviene en los agentes 2 (extracción) y 4 (redacción) y, de forma opcional, en embeddings del Agente 3; la extracción técnica, la vinculación y las decisiones son deterministas y reproducibles. La consulta del catálogo se expone primero mediante un servidor MCP, y el chat queda como capacidad opcional posterior.

Qué prueba esta corrida y qué no. La corrida prueba que el pipeline es medible y que la decisión de umbral puede trazarse a evidencia; no prueba que el modelo de gobernanza funcione en operación. Faltan datos reales, una evaluación de los controles —aprobaciones, roles, política de incentivos y mecanismo de detención— y una medición de la carga de revisión. Esas comprobaciones corresponden al piloto con aplicaciones verificadas y a la simulación de los niveles de detención del Hito 3.

2. Inventario y alineamiento con principios OCDE

La OCDE —Organización para la Cooperación y el Desarrollo Económicos (OECD, en inglés)— es la referencia internacional en principios de IA: sus recomendaciones no son vinculantes, pero inspiran la normativa peruana. La matriz recoge las capacidades de IA del APM y las contrasta con sus cinco principios (2024): crecimiento inclusivo y bienestar; derechos humanos y valores democráticos, incluidas la privacidad y la equidad; transparencia y explicabilidad; robustez, seguridad y protección; y rendición de cuentas. Ninguna capacidad está en operación: los agentes 1 a 4 existen como prototipo y el resto está en diseño. El nivel de impacto es una estimación sobre el diseño actual.

Principios adoptados y su efecto. El marco ético combina los cinco principios de la OCDE (2024) con la Recomendación de la UNESCO (2021), de donde resultan las diez dimensiones de la sección 3. Cada principio deja una huella verificable en el proyecto: el bienestar, en captura sin fricción y análisis consultivos; los derechos humanos y la equidad, en seudonimización, minimización y prohibición de decidir sobre personas; la transparencia y la explicabilidad, en procedencia por atributo y evidencia primaria citable; la robustez y la seguridad, en parsers deterministas, validación contra esquema y mecanismo de detención; y la rendición de cuentas,

en la prohibición de que un agente apruebe y en la bitácora de aprobaciones. La Tabla 2.1 contrasta cada capacidad con estos principios.

Tabla 2.1 — Matriz de alineamiento OCDE

Iniciativa IA (capacidad del APM)	Área responsable y estado	Principio OCDE impactado	Impacto	Observaciones
Agente 1 · Code-to-Catalog	Arquitectura TI; equipos de desarrollo. Prototipo; producción en F3	Transparencia; privacidad; robustez	Alto	Parsers deterministas, sin LLM; cita hash de commit y línea. Lee autores de commits (datos personales): minimización y seudonimización.
Agente 2 · Dark Data Miner	Arquitectura TI; contrataciones. Prototipo; producción en F4	Privacidad; transparencia; robustez	Alto	LLM con extracción guiada por esquema; cita documento, página y cláusula. Contratos con montos y firmantes: Confidenciales.
Agente 3 · Reconciliador Semántico	Arquitectura TI; Gobierno de Arquitectura. Prototipo; producción en F3	Robustez; rendición de cuentas	Alto	Score 0–1 y umbral único (propuesto: 0,85); bajo el umbral, «Requiere Verificación». Huérfanos y conflictos a revisión humana; nunca fuerza un vínculo.
Agente 4 · Micro-Nudge	Arquitectura TI; dueños técnicos. Prototipo; producción en F4	Derechos humanos y bienestar; supervisión humana	Medio	Preguntas de un clic; el LLM solo redacta. Riesgo de fatiga: límite de frecuencia, resumen semanal y escalamiento.
Servidor MCP de consulta	Arquitectura TI. Diseño (F4)	Transparencia; seguridad	Medio	Consulta con permisos heredados y citas, antes que un chat propio. Los datos Restringidos nunca se exponen.
Asistentes downstream (edición asistida, arquitecturas base)	Arquitectura TI; equipos de aplicación. Diseño (F4)	Rendición de cuentas; supervisión humana	Medio	Borradores auditados y vistas preliminares que el arquitecto valida antes de incorporarlas.
Vulnerabilidades y obsolescencia (CVE, EOL)	Seguridad de la Información; Arquitectura TI. Diseño (F2)	Robustez, seguridad y protección	Alto	Define qué se corrige primero con fuentes abiertas; los tickets en ITSM requieren aprobación.
Analítica: TIME, what-if, informes; chat opcional	Arquitectura TI. Diseño (F5)	Transparencia; bienestar	Medio	Resultados consultivos con fuente y supuestos. El chat del portafolio es opcional y posterior.
Bitácora de auditoría y procedencia	Arquitectura TI; Auditoría interna. Diseño (F1); el prototipo ya emite evidencia y score	Transparencia; rendición de cuentas	Alto	Registra evidencia primaria, score, versión del agente, reglas, modelo y aprobador; habilita los demás controles.

Cinco de las nueve capacidades tienen impacto alto y cuatro pertenecen a la capa upstream: los agentes 1, 2 y 3 producen los datos sobre los que se apoya todo lo demás, y la bitácora habilita la trazabilidad. En los agentes, la mitigación principal ya consta en el diseño (evidencia primaria, umbral de revisión y aprobación humana); en vulnerabilidades, la creación de tickets requiere aprobación. La privacidad se concentra en los agentes 1 y 2, que leen autores de commits y firmantes de contratos. El chat, que en un enfoque centrado en la conversación sería la capacidad principal, queda como opción de F5.

3. Evaluación de riesgos y criterios de aceptabilidad

El marco tiene 10 dimensiones éticas: equidad y no discriminación, transparencia, explicabilidad, responsabilidad y rendición de cuentas, privacidad y protección de datos, seguridad, robustez y fiabilidad, supervisión humana, sostenibilidad, y bienestar y beneficio. Se basa en los principios de la OCDE (2024) y en la Recomendación de la UNESCO (2021). Añade 5 dimensiones de impacto: operativo, financiero, regulatorio y legal, reputacional, y personas o clientes. El nivel de aceptabilidad es A (aceptable), A+C (aceptable con controles) o NA (no aceptable). La matriz incluye los riesgos propios del pipeline: vinculación errónea, datos personales en commits y contratos, y fatiga por micro-nudges. Las frecuencias de revisión son propuestas del autor.

Tabla 3.1 — Matriz de riesgos, aceptabilidad y controles mínimos

Dimensión ética	Riesgo concreto en el APM	Impacto	Nivel	Control mínimo, revisión y condición de cambio
Equidad y no discriminación	El puntaje de criticidad y la matriz TIME penalizan aplicaciones o equipos con datos incompletos; las aplicaciones sin repositorio accesible quedan subrepresentadas.	Operativo	A+C	Reglas de criticidad configurables y versionadas; completitud del dato visible junto a cada puntaje; retiros solo informativos. Gobierno de Arquitectura revisa una muestra semestral. Cambiaría si las recomendaciones se aplicaran sin revisión.
Transparencia	Los usuarios no distinguen qué datos provienen de una persona, de una ingesta, de un agente o de una publicación automática.	Reputacional	A+C	Procedencia por atributo (fuente, método, evidencia, fecha, autor, confianza y estado) y etiqueta visible de sugerencia de IA. Revisión en la auditoría periódica del catálogo. Cambiaría si quedaran campos sin procedencia.
Explicabilidad	Atributos o recomendaciones (retirar una aplicación, priorizar una CVE) sin sustento verificable.	Financiero	A+C	Cada atributo cita su evidencia primaria (archivo y línea con hash, o documento, página y cláusula); las sugerencias muestran diferencias y la bitácora guarda versiones de agente, reglas, modelo y prompt. Muestreo por el arquitecto. Cambiaría si se publicaran valores sin cita (pasaría a NA).
Responsabilidad y rendición de cuentas	Un cambio queda atribuido «al agente» sin responsable humano, o una publicación automática no tiene a quién responder.	Regulatorio y legal	A+C	Los agentes no aprueban; solo los atributos técnicos deterministas se publican automáticamente, trazados y reversibles, y toda otra publicación tiene un aprobador distinto de quien propone. Gobierno de Arquitectura revisa la bitácora. Cambiaría si un atributo crítico se publicara sin aprobador.
Privacidad y protección de datos	Correos de autores de commits y firmantes de contratos son datos personales; el Agente 2 procesa contratos con montos y firmantes y permisos amplios podrían exponerlos.	Regulatorio y legal; personas	A+C	Minimización y seudonimización de autores; contratos y licencias Confidenciales y no indexados para consulta; clasificación en cuatro niveles; los Restringidos no se cargan. Revisión de Cumplimiento y Seguridad antes de F3 y F4. Cambiaría si se cargaran Restringidos (pasaría a NA).
Seguridad	Agentes con acceso a repositorios, CI/CD, documentación, CMDB e ITSM; inyección de prompts en contenido externo; secretos expuestos en repositorios.	Operativo	A+C	OIDC/SSO y RBAC/ABAC; identidad propia por agente con mínimo privilegio; contenedores aislados de solo lectura; contenido externo no confiable; secretos descartados en la ingesta. Seguridad revisa la matriz de permisos por fase. Cambiaría si un agente obtuviera escritura externa sin aprobación.

Dimensión ética	Riesgo concreto en el APM	Impacto	Nivel	Control mínimo, revisión y condición de cambio
Robustez y fiabilidad	Vinculación errónea (fusionar dos aplicaciones o separar una), campos contractuales mal extraídos y CVE mal relacionadas.	Operativo	A+C	Reconciliación anclada en el catálogo con reglas deterministas; score calibrado contra un conjunto verificado; umbral único bajo el cual el valor queda en «Requiere Verificación»; fusiones, conflictos y huérfanos a revisión. Medición de precisión y exhaustividad en el piloto y ante cada cambio. Cambiaría si la precisión cayera bajo la meta o se publicaran vínculos bajo el umbral.
Supervisión humana	Sesgo de automatización y fatiga: aprobaciones en un clic, micro-nudges sin leer o saturación de la cola de revisión.	Operativo	A+C	Diferencias y evidencia visibles; límite de preguntas por persona y resumen semanal; vencimiento y escalamiento al arquitecto; carga por lotes priorizados y segunda revisión por muestreo. Seguimiento de tasa de respuesta, cola y aprobación sin edición. Cambiaría si la aprobación sin edición se acercara a 100 % o cayera la respuesta.
Sostenibilidad	Re-escaneo continuo en cada evento de CI/CD y extracción con LLM, con consumo y costos variables sin límite.	Financiero	A+C	Frecuencia de escaneo y presupuesto de consumo por agente; LLM reservado al texto no estructurado; límite de pasos por ejecución. Revisión de costos al cierre de cada fase. Cambiaría si el consumo superara el presupuesto (pasaría a NA).
Bienestar y beneficio	Dependencia excesiva de la IA, pérdida de criterio de los arquitectos, carga adicional sobre desarrolladores y beneficios sin medir.	Personas y clientes	A	Capacitación en uso responsable; indicadores de beneficio (cobertura, respuesta a micro-nudges, tiempo de revisión) acordados con la dirección. Revisión semestral. Cambiaría si los KPI no mostraran beneficio.

3.1 Criterios de aceptabilidad diferenciados

El mismo agente puede ser aceptable para leer y no serlo para decidir. La clasificación por tipo de uso evita juicios globales sobre «la IA» y permite elevar el nivel de control cuando cambia el uso, no cuando cambia la herramienta.

Tabla 3.2 — Criterios de aceptabilidad según el tipo de uso

Tipo de uso	Ejemplos en el APM	Criterio de aceptabilidad	Condición para elevar el nivel
Lectura y análisis	Consulta del catálogo por servidor MCP, puntajes, análisis de impacto, alertas; chat opcional (F5).	Aceptable con citas a registros del catálogo y registro de la consulta.	Si se usa para decisiones de inversión: revisión humana documentada.
Publicación automática de atributos técnicos	Stack, versiones, dependencias y endpoints extraídos por parsers deterministas (Agente 1).	Aceptable con controles: solo reglas deterministas (sin LLM), evidencia primaria, reversible y sin sobrescribir valores validados.	Si se extendiera a atributos inferidos por LLM o críticos: NA.
Sugerencia de cambio (escritura controlada)	Hipótesis de los agentes 2 y 3, micro-nudges del Agente 4, edición asistida y arquitecturas base.	Aceptable con controles: borrador con evidencia y score; bajo el umbral, «Requiere Verificación»; aprobación humana de atributos críticos.	Si el volumen satura la revisión: ajustar umbral y lotes antes que sumar revisores.
Acción hacia sistemas externos o personas	Tickets en ITSM; micro-nudges en Teams, Slack o pull requests; lectura de repositorios, CMDB y contratos.	No aceptable sin matriz de permisos de mínimo privilegio, identidad dedicada, límite de frecuencia y mecanismo de detención.	Definir permisos y límites con revisión de Seguridad de la Información.

La correspondencia entre los cinco principios y las diez dimensiones es la siguiente.

Tabla 3.3 — Correspondencia entre principios y dimensiones

Principio OCDE	Dimensiones éticas que lo desarrollan
Crecimiento inclusivo y bienestar	Bienestar y beneficio; sostenibilidad
Derechos humanos y equidad	Equidad y no discriminación; privacidad y protección de datos
Transparencia y explicabilidad	Transparencia; explicabilidad
Robustez y seguridad	Seguridad; robustez y fiabilidad
Rendición de cuentas	Responsabilidad y rendición de cuentas; supervisión humana

Dos riesgos merecen seguimiento ejecutivo. La vinculación errónea es el más crítico porque contamina todos los análisis posteriores y es difícil de detectar sin evidencia primaria visible; por eso la fusión y la separación de entidades son siempre reversibles y quedan en la bitácora. La fatiga de revisión es el segundo: un pipeline que genera más trabajo del que ahorra pierde su justificación, de modo que la carga de revisión se mide como KPI y no solo la precisión.

4. Gobernanza de proyectos y gestión de proveedores

La evaluación se apoya en la documentación de arquitectura del proyecto (Documentación del proyecto APM, 2026) y en los resultados del prototipo; cada fila indica su evidencia. Cada criterio tiene uno de tres estados: Diseñado (consta en la documentación), Propuesto (propuesta del autor en este informe, sin validar ni implementar) o Pendiente (falta información no verificable aquí, como un contrato o un dictamen). Ninguna propuesta se califica como cumplida, y todas deben validarse por las funciones de la sección 6.1 antes de implementarse.

4.1 Checklist de evaluación del proveedor y de la solución IA

Tabla 4.1 — Checklist de la solución y del proveedor

Criterio	Requerimiento mínimo	Estado	Evidencia y acción propuesta
Origen de la solución	Identificar si es interna, externa o mixta.	Diseñado	Construcción interna sobre fuentes y formatos abiertos (recomendado). Si la organización ya tiene un proveedor de APM/EA, se reutiliza con condiciones de portabilidad; el LLM es el único servicio externo y se consume tras una capa intercambiable.
Responsable institucional	Definir área dueña, responsable funcional y técnico.	Propuesto	Arquitectura TI es dueña del producto, de los agentes y de sus reglas (6.1). Falta designar responsables nominales.
Documentación funcional	Describir qué hace, usuarios, alcance, límites y proceso impactado.	Diseñado	IA agéntica (pipeline), Catálogos e Interfaz. Mantenerla al día y documentar los límites de cada agente.
Documentación técnica	Documentar arquitectura, modelo, datos, integraciones, seguridad y versiones.	Propuesto	Arquitectura de solución, Modelo de datos y documentación del prototipo. Añadir una ficha técnica por agente (propósito, fuentes, uso de LLM, permisos, versión de reglas y modelo) antes de activarlo.
Desempeño / KPI	Definir precisión, errores, latencia, costo y disponibilidad.	Propuesto	Indicadores de la Tabla 4.4; la primera calibración ya mide precisión y exhaustividad de la reconciliación sobre el conjunto de prueba.
Datos utilizados	Clasificar los datos: públicos, internos, confidenciales o restringidos.	Propuesto	Cuatro niveles aplicados a los atributos del APM (Tabla 4.3); contratos y licencias Confidenciales; autores de commits seudonimizados.

Criterio	Requerimiento mínimo	Estado	Evidencia y acción propuesta
Trazabilidad	Registrar fuente, usuario, fecha, prompt, salida, versión y validación humana.	Diseñado	Bitácora por acción de agente y procedencia con evidencia primaria. Extenderla a las consultas por servidor MCP (usuario, herramienta, registros devueltos).
Auditabilidad	Permitir revisión posterior por auditoría, control interno, legal o seguridad.	Diseñado	Bitácora de solo anexado y pantalla de auditoría. Acceso de solo lectura por rol para Auditoría interna, Seguridad y Cumplimiento.
Gestión de proveedor	Incluir SLA, soporte, propiedad de datos, portabilidad, confidencialidad y responsabilidad.	Pendiente	No hay contrato: el proveedor de LLM aún no se selecciona. Antes de procesar datos reales, verificar que no use los datos para entrenar, ubicación y retención, SLA y límites de la capa gratuita. Hasta entonces, solo se usan datos de prueba.
Continuidad operativa	Definir qué ocurre si falla el proveedor, la API, el modelo, la nube o la integración.	Diseñado	Mecanismo de detención y capa de proveedor intercambiable; los agentes 1 y 3 no usan LLM y siguen operando. En último caso, búsqueda y filtros sin IA (Tabla 4.5).

Capacidades mínimas del proveedor. Reutilizar un APM comercial exige cuatro capacidades técnicas —exportación completa por API en formato abierto, identificador estable con claves externas, procedencia y auditoría por atributo, y control de acceso por rol con aprobaciones registradas— y tres contractuales: propiedad del dato, retención definida y ruta de salida. Si falta alguna, el proveedor sirve como fuente, no como registro maestro.

4.2 Gobernanza de agentes IA

Los agentes del pipeline se conectan a repositorios de código y CI/CD, a repositorios documentales de contratos y TDR, al catálogo existente (Excel migrado y CMDB) y a canales de mensajería; los asistentes downstream, a fuentes de CVE y EOL, a ITSM y al servidor MCP. La supervisión es humana en el bucle (HITL), con una excepción explícita y acotada: los atributos técnicos deterministas se publican automáticamente con procedencia. La tabla justifica esa excepción como un riesgo aceptado con controles.

Tabla 4.2 — Gobernanza del agente IA

Grupo	Criterio	Estado	Medida propuesta y evidencia
Autonomía y alcance	Nivel de autonomía	Diseñado	Dos niveles: (a) publicación automática solo de atributos técnicos de parsers deterministas, con evidencia, reversible y sin sobrescribir valores validados; (b) todo lo demás (dueño, criticidad, costo, contrato, huérfanos) requiere aprobación humana. Riesgo aceptado: un error de parser queda publicado hasta que alguien lo corrige; se mitiga con evidencia visible, reversión y muestreo.
Autonomía y alcance	Herramientas conectadas y tipo de acciones	Diseñado	Agente 1: Git, CI/CD y manifiestos. Agente 2: repositorio documental. Agente 3: catálogo (Excel, CMDB). Agente 4: Teams, Slack o pull requests. Lectura en contenedores aislados; escritura solo como Borrador vía API; los micro-nudges son la única acción hacia personas. Ningún agente aprueba ni ejecuta transacciones críticas.
Control y supervisión	Política de permisos	Diseñado	Identidad propia por agente con mínimo privilegio; en consultas, permisos heredados de la persona y nunca la unión de ambos; credenciales en almacén de secretos. Seguridad de la Información revisa la matriz antes de cada fase.
Control y supervisión	Registros auditables	Diseñado	Evidencia primaria, score, versión de agente, reglas, modelo y prompt, micro-nudge enviado y respuesta, aprobador y fecha, con acceso de solo lectura.

Grupo	Criterio	Estado	Medida propuesta y evidencia
Control y supervisión	Validación humana	Diseñado	Doble escalón: el dueño técnico confirma por micro-nudge y Gobierno de Arquitectura aprueba el Fact Sheet. Bajo el umbral, «Requiere Verificación». Muestreo (HOTL) de lo publicado automáticamente; plazo propuesto de 5 días hábiles.
Resiliencia y continuidad	Mecanismo de detención	Diseñado	Tres niveles (Tabla 4.5): detener un agente, modo solo lectura y operación sin IA. La asignación de quién los activa es propuesta del autor y se simula durante el piloto.
Resiliencia y continuidad	Gestión de memoria y plan de contingencia	Propuesto	Los agentes del pipeline no tienen memoria conversacional: su estado es la evidencia y la procedencia guardadas en el APM. Las consultas (MCP o chat) no conservan memoria entre sesiones salvo un historial de 90 días (propuesta) y recuperan contexto con permisos heredados. Degradación escalonada con responsable y criterios de activación.
Dependencias IA	Modelo base y APIs externas	Diseñado	El LLM interviene en el Agente 2 (extracción), en el 4 (redacción) y, opcionalmente, en embeddings del 3; versión fijada por entorno y compuerta de evals ante cambios. Fuentes externas gratuitas: NVD, OSV, endoflife.date y una tabla propia de EOL; si una falla, el último dato ingerido sigue visible.
Dependencias IA	Costos variables y continuidad del proveedor	Propuesto	Sin licencias por usuario. Componentes variables: tokens (agentes 2 y 4), cómputo de escaneo e infraestructura; presupuesto por agente, límite de pasos y alerta al 80 %, con montos por fijar antes del piloto. Portabilidad por diseño: interfaz propia (generar, extraer contra esquema, embeddings) con adaptadores; cambiar de embeddings obliga a reindexar.

4.3 Clasificación de datos por sensibilidad

La clasificación tiene cuatro niveles y se aplica a los atributos del APM. El APM contiene metadatos de arquitectura y, con el Agente 2, datos contractuales; no contiene datos de clientes.

Tabla 4.3 — Clasificación de datos del APM y uso permitido por el agente

Nivel	Atributos del APM (ejemplos)	Uso por el agente y control
Público	Información de fuentes públicas: CVE de NVD/OSV, fechas de fin de vida (endoflife.date).	Libre. Registrar la fuente y la fecha de ingesta.
Interno	Nombre, descripción, etiquetas, ciclo de vida, capacidades, relaciones, dependencias, stack detectado, criticidad, modelo TIME, arquitecturas y diagramas.	Permitido con permisos heredados. Procedencia por atributo y registro de consultas.
Confidencial	Contratos, TDR y licencias (proveedor, montos, vigencias, SLA); vulnerabilidades abiertas por aplicación; detalle de integraciones; costos; contactos y responsables; autores de commits seudonimizados.	Solo para roles autorizados; autores y firmantes solo para Arquitectura y sin indexar para consulta. Seudonimización (el autor se guarda con un identificador interno y se resuelve solo al enviar el micro-nudge), minimización y revisión de Seguridad.
Restringido	Credenciales y secretos hallados en repositorios; datos de clientes y datos personales sensibles.	Prohibido: no se cargan en el APM ni se exponen al agente. Filtros de ingesta; el escaneo descarta secretos y se prueba antes de F3.

El acceso se segmenta por rol: lectura para todo TI sobre datos Públicos e Internos; edición limitada a los equipos de aplicación sobre sus fichas; aprobación en Gobierno de Arquitectura; y descarga de reportes según rol y nivel de detalle. Los Confidenciales quedan para roles autorizados y los Restringidos no se cargan.

4.4 Indicadores (KPI) y primera medición

Las metas son propuestas y se fijan en el piloto de calibración sobre un conjunto verificado de aplicaciones. El score es heurístico (de 0 a 1) y no es una probabilidad hasta calibrarse; en el prototipo combina similitud nominal (0,50), congruencia técnica (0,35) y consistencia de dominio (0,15). La primera corrida ya aporta una medición de reconciliación, pero con 36 casos de prueba no alcanza para fijar metas definitivas. El chat del portafolio solo tendría indicadores si se activa en F5.

Tabla 4.4 — KPI propuestos y primera medición disponible

Indicador	Definición y meta propuesta	Medición y uso
Precisión y exhaustividad de la extracción	Por agente (1 y 2): atributos correctos sobre extraídos y extraídos sobre existentes, en el conjunto verificado. Meta: se fija en el piloto.	Compuerta de evals ante cambios de reglas, modelo o fuente. Sin medición todavía para los agentes 1 y 2.
Precisión y exhaustividad de la reconciliación	Vínculos correctos sobre propuestos y encontrados sobre reales. Meta: se fija en el piloto y es la base para calibrar el umbral.	Primera corrida de prueba: F1 macro 91,1 % en calibración (26 casos) y 59,9 % en evaluación (10 casos) con los parámetros calibrados. No concluyente; se amplía el conjunto.
Proporción en «Requiere Verificación»	Hipótesis bajo el umbral sobre el total. Rango a fijar en el piloto.	Con umbral 0,70: 7 de 18 hipótesis a revisión. Muy alta: el pipeline no ahorra trabajo; muy baja: revisar si el umbral es laxo.
Tasa de respuesta a micro-nudges	Respondidos dentro del plazo sobre enviados, y tiempo de respuesta. Meta: se fija en el piloto.	Si cae, se revisan el límite de frecuencia y la redacción.
Cola de revisión y plazo	Tamaño por tipo y antigüedad (p50 y p95) frente al plazo. Meta propuesta: p95 ≤ 5 días hábiles.	Si crece de forma sostenida, se ajustan umbral y lotes antes que el número de revisores.
Cambios gobernados con aprobador	Porcentaje de atributos críticos publicados con aprobador humano registrado. Meta: 100 % (regla de diseño).	Cualquier desvío activa el nivel 2 del mecanismo de detención.
Consumo y latencia	Costo mensual frente al presupuesto (≤ 100 %, alerta al 80 %) y latencia p95 del servidor MCP.	Los montos dependen de los límites vigentes; la latencia se fija en el piloto.

4.5 Mecanismo de detención y contingencia

Tabla 4.5 — Mecanismo de detención en tres niveles

Nivel	Mecanismo	Activación y efecto
1. Detener un agente	Deshabilitar la identidad del agente o revocar sus herramientas.	Comportamiento incorrecto, precisión bajo la meta, bucle o consumo anómalo. El resto del APM y de los agentes sigue operando.
2. Modo solo lectura	Bandera de solo lectura para agentes en la API: ningún agente crea borradores, publica automáticamente ni envía micro-nudges.	Publicación sin aprobación, sospecha de exposición de datos personales o cambio de modelo sin evals. Los agentes solo responden consultas.
3. Sin IA	Desactivar la capa de IA; la interfaz usa búsqueda simple, filtros y vista de grafo.	Indisponibilidad del proveedor, incidente de seguridad o decisión de Seguridad de la Información. El registro y la aprobación manuales continúan.

El mecanismo consta en la arquitectura de solución; la asignación de quién lo activa es propuesta del autor. Arquitectura TI activaría los niveles 1 y 2, Seguridad de la Información podría solicitar cualquiera de los tres y TI Operaciones ejecutaría el nivel 3. Durante el piloto se simularía la degradación completa.

5. Lineamientos operativos para uso responsable de IA

Cada lineamiento identifica al actor, define el uso concreto, establece una condición verificable y cita su fundamento, de modo que sea auditable y no una declaración de intenciones. Se clasifican en usos permitidos, restringidos y no permitidos. Los fundamentos son OCDE (2024), NIST (2023), ISO (2023), la Ley 29733 y su reglamento, la Ley 31814 y su reglamento (DS 115-2025-PCM) y la política interna del APM.

5.1 Clasificación de usos de IA agéntica

Tabla 5.1 — Lineamientos para IA agéntica

#	Actor	Caso de uso	Clasificación	Condición verificable	Fundamento
1	Agente 1	Publicar atributos técnicos (stack, versiones, dependencias, endpoints)	Permitido	Solo parsers deterministas, con hash de commit y ruta; reversible; nunca sobrescribe un valor validado por una persona.	OCDE (transparencia, rendición de cuentas); ISO/IEC 42001
2	Agente 2 y arquitecto	Extraer proveedor, vigencia, SLA y licencias de contratos y TDR	Permitido	Cada valor cita documento, página y cláusula y se valida contra el esquema; sin cita, el campo queda vacío y el Fact Sheet sigue como Borrador hasta la aprobación.	OCDE (transparencia); NIST AI RMF; Ley 29733
3	Agente 4 y dueño técnico	Enviar micro-solicitudes en Teams, Slack o pull requests	Restringido	Solo si el score está bajo el umbral, falta un atributo obligatorio o el dueño fue inferido; máximo de preguntas por persona, resumen semanal del excedente, vencimiento en 5 días hábiles y escalamiento.	OCDE (bienestar, supervisión humana); política interna
4	Agente 3 y arquitecto	Tratar candidatos huérfanos (posible Shadow IT) y conflictos	Restringido	Nunca se vinculan ni se dan de alta automáticamente: van a la cola de revisión; el arquitecto decide y el alta requiere aprobación de Gobierno de Arquitectura.	OCDE (robustez, rendición de cuentas); NIST AI RMF
5	Agente 1 y Seguridad	Leer autores de commits para sugerir un responsable técnico	Restringido	Minimización y seudonimización; visible solo para el rol de Arquitectura; no se indexa; la sugerencia se confirma por micro-nudge.	Ley 29733 y su reglamento; OCDE (privacidad)
6	Proveedor de LLM	Recibir texto de contratos o del catálogo para extraer o redactar	Restringido	Solo datos Públicos e Internos; Confidenciales con aprobación de Seguridad y términos verificados; Restringidos nunca.	Ley 29733; ISO/IEC 42001
7	Cualquier agente	Aprobar o modificar atributos críticos o dar de alta/baja Fact Sheets	No permitido	Solo con aprobación de Gobierno de Arquitectura; la identidad del agente no tiene permiso de aprobar.	OCDE (supervisión humana); política interna
8	Cualquier agente	Decidir retiros o evaluar a personas o equipos	No permitido	Los análisis TIME y what-if son consultivos; las métricas de respuesta no se usan para evaluar personas.	OCDE (equidad); Ley 31814 y DS 115-2025-PCM

5.2 Lineamientos para IA generativa

La IA generativa interviene en pocas piezas: la extracción contractual (Agente 2), la redacción de micro-nudges (Agente 4) y los asistentes downstream. El chat del portafolio es opcional y posterior (F5); la consulta se expone antes mediante el servidor MCP.

Tabla 5.2 — Lineamientos para IA generativa

Actor y uso	Riesgo asociado	Lineamiento verificable y evidencia	Fundamento
Agente 2: extracción de campos de contratos y TDR	Campo inventado o mal leído (OCR)	Extracción contra esquema; sin cita textual el campo queda vacío y se pregunta; entra como Borrador sujeto a aprobación. Evidencia: documento, página y cláusula.	OCDE (transparencia); NIST AI RMF
Agente 4: redacción de la pregunta del micro-nudge	Pregunta confusa o que expone datos de otra persona	La lógica (cuándo, a quién y qué preguntar) es determinista; el LLM solo redacta desde plantilla y no añade datos ajenos. Evidencia: plantilla, texto enviado y respuesta registrados.	Ley 29733; OCDE (privacidad)
Arquitecto: arquitecturas base y revisión contra estándares	Vista errónea tratada como definitiva o falsa conformidad	La vista se marca como preliminar y no se incorpora sin validación del arquitecto; los hallazgos citan el estándar y son consultivos. Evidencia: aprobador, fecha y diferencias.	ISO/IEC 42001; política interna
Usuario: consulta por servidor MCP o chat opcional (F5)	Respuesta inventada o sin respaldo	Toda respuesta cita registros del catálogo; si no hay registro, lo indica. Evidencia: registro de la consulta, fuentes citadas y versión del modelo.	OCDE (transparencia); NIST AI RMF
Dirección y arquitectos: informes ejecutivos (F5)	Cifras no verificadas llegan a la alta dirección	Cada informe indica fuente y fecha, y una persona lo revisa antes de distribuirlo. Evidencia: registro de la revisión y versión del informe.	OCDE (rendición de cuentas); DS 115-2025-PCM

6. Modelo institucional de gobernanza de IA

La solución está pensada para el equipo de Arquitectura TI, que se propone como dueño del APM y de su capa de IA. El modelo aprovecha las instancias que el diseño ya define (equipos de aplicación y Gobierno de Arquitectura) y suma funciones de apoyo descritas de forma genérica. La Dirección de TI patrocina la política que hace del mantenimiento de la ficha parte del proceso operativo y respalda la obligación de reportar.

6.1 Estructura de roles y responsabilidades

Tabla 6.1 — Roles y responsabilidades

Rol	Responsabilidad en gobernanza de IA	Participación y brecha
Arquitectura TI	Dueña del producto APM, de los agentes y de sus reglas y modelos (configuración, umbral, evals, versiones). Aprueba cambios de agentes y activa el mecanismo de detención.	Dueña. Designar responsables nominales: líder del producto y responsable de agentes.
Gobierno de Arquitectura	Instancia de aprobación dentro de Arquitectura TI: aprueba atributos críticos, decide sobre huérfanos y conflictos y define las reglas de criticidad.	Dueña. Fijar composición y plazo de revisión (propuesto: 5 días hábiles).
Equipos de aplicación	Mantienen sus Fact Sheets (rol Responsible), responden micro-nudges y validan las sugerencias que les afectan.	Usuaria. Capacitación en uso responsable.
Seguridad de la Información	Revisa permisos, conectores y entorno aislado; puede solicitar el mecanismo de detención.	Consultada. Criterios de revisión específicos para agentes.
Riesgos	Incorpora el riesgo de IA en la gestión de riesgo tecnológico y revisa la matriz de la sección 3.	Consultada. Confirmar que su taxonomía cubre modelos de IA.
Cumplimiento y Legal	Determinan el marco normativo aplicable (Ley 29733 y su reglamento, Ley 31814) y la retención de registros.	Consultada. Dictamen sobre el alcance normativo.
Datos	Valida la clasificación de la Tabla 4.3, las fuentes autoritativas y el acceso a contratos y TDR.	Consultada. Aplicar la clasificación al APM.
TI Operaciones y Auditoría interna	TI Operaciones administra infraestructura, conectores, secretos, monitoreo y continuidad (nivel 3). Auditoría revisa la bitácora y los controles de forma independiente.	Soporte y consultada. Procedimientos de operación; incluir el APM en el plan anual de auditoría.

6.2 Integración normativa

No se afirman exigencias legales específicas: la tabla indica qué debe confirmar Cumplimiento o Legal. El reglamento de la Ley 31814 adopta, según la información pública consultada, un enfoque basado en riesgos. La hipótesis es que los usos del APM no evalúan a clientes ni a personal y no serían de alto riesgo; Legal debe confirmarla. El marco se plantea para una organización peruana, sin normativa sectorial.

Tabla 6.2 — Alineamiento normativo

Marco normativo	Elemento del modelo que aplica	Estado y acción necesaria
Ley 31814 (2023)	Principios de uso responsable, supervisión humana, trazabilidad y bitácora de auditoría.	Propuesto. Legal confirma el alcance para la organización y los usos del APM.
DS 115-2025-PCM (2025), reglamento de la Ley 31814	Clasificación del nivel de riesgo de cada capacidad (Tabla 3.1).	Propuesto. Legal valida el nivel de riesgo y si surgen obligaciones de registro o evaluación.
NIST AI RMF 1.0 (2023)	Gobernar: roles y política (6.1). Mapear: inventario (sección 2). Medir: KPI (Tabla 4.4). Gestionar: umbral, bandeja de aprobación, bitácora y detención (Tabla 4.5).	Propuesto. Implementar el ciclo de revisión periódica de los KPI tras el piloto.
ISO/IEC 42001:2023 (2023)	Sistema de gestión de IA: políticas, roles, riesgos, controles y mejora.	Pendiente. Análisis de brechas; no se plantea certificación en esta etapa.
Ley 29733 (2011) y su reglamento (2024)	Autores de commits y firmantes de contratos como datos personales: minimización, seudonimización y acceso restringido; clasificación (Tabla 4.3).	Diseñado. Cumplimiento confirma la base del tratamiento y las obligaciones adicionales.
OCDE (2024), UNESCO (2021) y Política Nacional de Transformación Digital al 2030	Marco de las 10 dimensiones (sección 3) y diseño del pipeline: doble escalón humano, citas primarias, umbral y bitácora.	Diseñado. Revisar si se actualizan los principios.
Política interna de uso de IA	Alineación del modelo con las políticas corporativas.	Pendiente. Identificar si existe y alinear los lineamientos de la sección 5.

6.3 Hoja de ruta adaptable

Se propone una hoja de ruta con cuatro hitos principales, que agrupan las fases F0 a F5 del producto. Cada hito tiene un plan de trabajo y una compuerta de cierre —una condición verificable— que se resuelve con evidencia. La hoja de ruta no fija fechas: está pensada para que la organización la adapte a sus tiempos, presupuesto y contexto; el punto de entrada y la duración cambian, pero se recomienda mantener las compuertas como criterio de avance. Supone cuatro condiciones: acceso a repositorios y, cuando exista, a la CMDB; patrocinio de la Dirección de TI; capacidad de revisión humana; y disposición a publicar la ficha para consulta. Sin ellas, el modelo no se sostiene.

Tabla 6.3 — Hitos y compuertas

Hito y fase	Plan de trabajo	Compuerta de cierre
Hito 1 · Cimientos y calibración (F0)	Portal y modelo ArchiMate versionados. Decisión de fuentes abiertas o reutilización del proveedor. Ampliación del lote de prueba y recalibración del score. Clasificación de datos y permisos por rol.	Lote de prueba ampliado, umbral documentado y permisos aprobados.
Hito 2 · Catálogo núcleo y seguridad (F1–F2)	Catálogo con control de acceso y auditoría. Migración del Excel como Borrador. Ingesta de CVE y EOL.	Catálogo con auditoría, CVE y EOL vinculados y ningún cambio sin aprobador.
Hito 3 · Descubrimiento técnico (F3)	Agentes 1 y 3 en solo lectura sobre repositorios, CI/CD y CMDB. Huérfanos y conflictos a revisión humana. Simulación del mecanismo de detención.	Score calibrado, cola de revisión dentro del plazo y cero publicaciones sin evidencia.
Hito 4 · Contratos, micro-nudges y analítica (F4–F5)	Agentes 2 y 4. Consulta por MCP. Asistentes validados por el arquitecto. Términos del proveedor de LLM. Analítica e informes. Brechas ISO/IEC 42001.	Evidencia contractual citada, micro-nudges respondidos en plazo y revisión sin hallazgos críticos.

La secuencia propuesta es una referencia. Una empresa sin CMDB ni catálogo confiable empieza por los Hitos 1 y 2; una con CMDB madura, por los Hitos 2 y 3; una con regulación intensa, por la clasificación de datos y los permisos antes del Hito 3; y una con presupuesto mínimo, por el Hito 1 con fuentes abiertas.

Adopción y carga. Dirección de TI comunica la política; Arquitectura TI forma a los equipos; cada dueño recibe un resumen mensual de su portafolio. Las señales de resistencia se miden — caída de respuesta a micro-nudges, cola que crece sin explicación, correcciones repetidas del mismo campo— y la carga de revisión se estima por rol (arquitecto, dueño técnico, aprobador) antes de ampliar el alcance. Si la carga supera la capacidad, se ajusta el umbral o se priorizan lotes.

7. Conclusiones y próximos pasos

- Arquitectura TI puede gobernar la IA agéntica del APM con mecanismos concretos y verificables. El diseño se concentra en la captura y la reconciliación de datos: cuatro agentes especializados, el LLM reservado al texto no estructurado y la regla «la IA propone con evidencia, la persona dispone».
- El riesgo de mayor impacto es la vinculación errónea y la publicación sin respaldo suficiente. Se controla con reconciliación anclada en el catálogo, score con umbral único y estado «Requiere Verificación», revisión humana de huérfanos y conflictos, y publicación automática limitada a atributos técnicos deterministas y reversibles. Los datos personales de commits y contratos se acotan con minimización y seudonimización.
- La primera calibración enseña que medir no basta: con 36 casos de prueba la combinación ganadora en calibración no generaliza y ningún umbral logra error cero. La decisión que sostienen los datos es mantener los umbrales como propuestas, ampliar el conjunto verificado y repetir el ejercicio antes de F3. Esa trazabilidad entre evidencia y decisión es, en sí, parte del modelo de gobernanza.
- La construcción sobre fuentes abiertas —o la reutilización de un proveedor existente con propiedad del dato, exportación y salida— y un proveedor de LLM intercambiable reducen la dependencia tecnológica. Escalar exige evidencia: el piloto debe fijar el umbral y las metas antes de F3, y las compuertas de cada hito son el criterio de avance.

Limitaciones y plan de evaluación. La evidencia es de diseño (ver 1.4). El plan es medir en el piloto, con aplicaciones verificadas: precisión y exhaustividad, carga y plazo de revisión, respuesta a micro-nudges, publicaciones sin aprobador e incidentes. Esas métricas son la compuerta para pasar al Hito 3.

Plan de acción por secuencia

Tabla 7.1 — Plan de acción por secuencia

#	Acción	Responsable	Requisito de entrada	Criterio de cierre
1	Nombrar al líder del producto y al responsable de agentes, y aprobar el inventario de la Tabla 2.1.	Arquitectura TI; Dirección de TI	Mandato de la Dirección	Responsables e inventario aprobados
2	Aprobar la política de mantenimiento de la ficha.	Dirección de TI	Responsables designados	Política publicada y comunicada
3	Elaborar la ficha técnica y los permisos de cada agente.	Arquitectura TI; Seguridad	Inventario y política aprobados	Revisión de Seguridad
4	Ampliar el lote de prueba y recalibrar el score; documentar el umbral y las metas de la Tabla 4.4.	Arquitectura TI; Gobierno de Arquitectura	Lote y pipeline operativos	Umbral y metas con evidencia
5	Validar la clasificación de datos de la Tabla 4.3 y la seudonimización de autores y firmantes.	Datos; Seguridad; Cumplimiento	Inventario y flujos identificados	Clasificación y reglas aprobadas
6	Elegir el proveedor de LLM y revisar sus términos; confirmar el alcance de la Ley 29733, la Ley 31814 y el DS 115-2025-PCM.	TI Operaciones; Cumplimiento; Legal	Casos de uso definidos	Términos verificados y dictamen legal

Glosario

CMDB / ITSM. Base de datos de configuración (inventario de infraestructura) y herramienta de mesa de ayuda donde se registran tickets.

CVE, CVSS, EPSS. Identificador de una vulnerabilidad pública (CVE), su severidad (CVSS) y la probabilidad de que sea explotada (EPSS).

Dark data / TDR. Información no estructurada que no llega al código ni a la CMDB, como contratos y Términos de Referencia (TDR).

Fact Sheet. Ficha de un activo del APM (aplicación, integración, tecnología, capacidad), con procedencia por atributo.

HITL / HOTL. Humano en el bucle (aprueba antes de que algo se publique) y humano sobre el bucle (supervisa por muestreo).

MCP. Model Context Protocol, protocolo abierto para exponer herramientas y datos a asistentes de IA; aquí, la vía de consulta del catálogo.

Micro-nudge. Micro-solicitud contextual de respuesta en un clic que se envía al responsable para confirmar o completar un dato.

SBOM. Lista de los componentes de software de una aplicación; base para correlacionar vulnerabilidades.

Score de confianza / umbral. Puntaje heurístico de 0 a 1 que el Reconciliador asigna a cada atributo o vínculo; no es una probabilidad hasta calibrarse. El umbral único (propuesto: 0,85) separa la aprobación de la «Requiere Verificación».

Shadow IT. Aplicaciones o componentes que operan fuera de la visibilidad formal de TI; en el pipeline aparecen como candidatos huérfanos.

TIME. Modelo de racionalización (tolerar, invertir, migrar, eliminar) según el ajuste funcional y técnico (SAP, s. f.).

Bibliografía

Backstage. (s. f.). Software Catalog. https://backstage.io/docs/features/software-catalog/

Congreso del Perú. (2011). Ley N.° 29733, Ley de Protección de Datos Personales. Diario Oficial El Peruano.

Congreso del Perú. (2023). Ley N.° 31814, Ley que promueve el uso de la inteligencia artificial en favor del desarrollo económico y social del país. https://www.gob.pe/institucion/congreso-de-la-republica/normas-legales/4565760-31814

Documentación del proyecto APM. (2026). Portal de arquitectura del APM: Arquitectura del sistema; Catálogos del portafolio; Modelo de datos; Gobierno y procedencia de datos; IA agéntica y funcionalidades; Arquitectura de solución y despliegue; Interfaz de usuario; Roadmap de implementación; Soluciones similares; Prototipo MVP del pipeline de descubrimiento e informes de calibración y evaluación [Documentación interna del proyecto].

ISO. (2023). ISO/IEC 42001:2023 Artificial intelligence management system. https://www.iso.org/standard/42001

Ministerio de Justicia y Derechos Humanos. (2024). Decreto Supremo N.° 016-2024-JUS, que aprueba el Reglamento de la Ley N.° 29733, Ley de Protección de Datos Personales. Diario Oficial El Peruano.

NIST. (2023). AI Risk Management Framework (AI RMF 1.0). https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf

OECD. (2024). OECD AI Principles. https://www.oecd.org/en/topics/ai-principles.html

OECD. (2025). Governing with Artificial Intelligence. https://www.oecd.org/en/publications/governing-with-artificial-intelligence_795de142-en.html

PCM. (2023). DS N.° 085-2023-PCM — Política Nacional Transformación Digital 2030.

PCM. (2025). DS N.° 115-2025-PCM — Reglamento Ley 31814. https://www.gob.pe/institucion/pcm/normas-legales/7133522-115-2025-pcm

SAP. (s. f.). TIME model — SAP LeanIX documentation. https://help.sap.com/docs/leanix/ea/time

The Open Group. (2022). ArchiMate 3.2 Specification. The Open Group.

UNESCO. (2021). Recommendation on the Ethics of AI. https://www.unesco.org/en/legal-affairs/recommendation-ethics-artificial-intelligence